

Cirque Corporation

Information Security Risk Assessment Procedure

Document ID: IS-CIRQ-PR-002-G

Category: Base Policy & ISMS Manual

Division: Procedure

Type: Global

Version: 1.1

Effective Date: June 2025

Review Date: June 2026

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to describe the systematic process for identifying, analyzing, and evaluating information security risks within Cirque's Information Security Management System (ISMS) scope, in accordance with ISO/IEC 27001:2022 Clause 6.1. This procedure implements the principles outlined in the IS-CIRQ-P-003-G: Risk Management Policy.

****2. Scope****

2. Scope

This procedure applies to all information assets, processes, and systems within the defined ISMS scope of Cirque. It covers both initial and periodic risk assessments, as well as ad-hoc assessments triggered by significant changes.

****3. Responsibilities****

3. Responsibilities

- ****IT Manager:**** Overall responsible for coordinating and

facilitating risk assessment activities, maintaining the Risk Assessment Register (IS-CIRQ-F-001-G), and ensuring adherence to this procedure.

- **Department Managers/Process Owners:** Provide input for asset identification, threat and vulnerability identification specific to their areas, and contribute to impact assessment.

- **IT Department Personnel:** Provide technical input on vulnerabilities, existing controls, and technical impacts, leveraging insights from security tools.

****4. Procedure****

4. Procedure

****4.1. Planning the Risk Assessment****

a. The IT Manager will schedule and plan risk assessment sessions. This includes defining the scope of the specific assessment (e.g., an annual full assessment, or a targeted assessment for a new system).

b. Identify and gather relevant documentation, including the ISMS Scope Document (IS-CIRQ-D-001-G), previous risk assessments, and the current information asset inventory.

c. Assemble a cross-functional risk assessment team, including representatives from IT, relevant department managers, and subject matter experts as needed.

****4.2. Information Asset Identification and Valuation****

a. For the defined assessment scope, identify all relevant information assets by leveraging the ****Asset Inventory maintained via RMM and associated spreadsheet****. This includes, but is not limited to, data (e.g., customer data, IP, financial), software (e.g., ERP, CAD, GitLab), hardware (e.g., servers, workstations, network devices), services (e.g., cloud services, internet access), and people.

b. For each identified asset, determine its business value and importance to Cirque's

operations, especially concerning its Confidentiality, Integrity, and Availability (CIA).

4.3. Threat Identification a. For each asset or group of assets, identify potential threats that could exploit vulnerabilities and cause harm. Threat identification will leverage insights from **Windows Defender for Business** (for common cyber threats and malware) as well as broader categories, including: * **Natural Disasters:** Fire, flood, earthquake. * **Environmental:** Power failure, HVAC failure. * **Human (Accidental):** Error, negligence, unintentional disclosure. * **Human (Deliberate):** Unauthorized access, theft, fraud, sabotage, sophisticated cyber-attacks (phishing, ransomware, zero-day exploits). * **Technical Failure:** Hardware failure, software bugs, network outage. b. Record identified threats in the IS-CIRQ-F-001-G: Risk Assessment Register.

4.4. Vulnerability Identification a. For each asset, identify existing vulnerabilities that could be exploited by identified threats. Vulnerability identification will heavily utilize **Windows Defender for Business** for endpoint and server vulnerabilities, alongside other sources such as: * Results from any network scans or penetration tests (if conducted). * Software and system configuration reviews. * Identified weaknesses in processes or human factors (e.g., lack of awareness). * Physical security weaknesses. b. Record identified vulnerabilities in the IS-CIRQ-F-001-G: Risk Assessment Register.

4.5. Existing Control Identification a. For each identified threat-vulnerability pair, identify any existing information security controls currently in place that mitigate the risk. This includes both technical (e.g., firewalls, encryption, Windows Defender for Business configurations) and non-technical (e.g., policies, training, physical security measures) controls. b. Record existing controls in the

4.6. Risk Analysis (Likelihood and Impact Assessment) a.

Likelihood Assessment: For each threat-vulnerability pair, assess the likelihood of the threat exploiting the vulnerability, considering the effectiveness of existing controls. Use the following qualitative scale: **Low:** Unlikely to occur in the foreseeable future (e.g., once every 5+ years). **Medium:** Could occur occasionally (e.g., once every 1-5 years). **High:** Likely to occur frequently (e.g., multiple times per year). b. **Impact Assessment:** For each threat-vulnerability pair, assess the potential business impact if the incident were to occur, considering the CIA of the affected assets. Use the following qualitative scale: **Low:** Minor disruption, limited financial loss, no significant legal/reputational damage. **Medium:** Moderate disruption, measurable financial loss, some reputational/legal impact, non-critical data breach. **High:** Severe disruption, significant financial loss, major reputational/legal damage, critical data breach (e.g., IP loss, severe privacy violation). c. Record both likelihood and impact in the IS-CIRQ-F-001-G: Risk Assessment Register.

4.7. Risk Evaluation a. Combine the likelihood and impact ratings to determine the inherent risk level (before additional treatment) using the following matrix:

Impact \ Likelihood
Low Likelihood | Medium Likelihood
High Likelihood

Low | Low | Medium | High
Medium | Low | Medium | High
High | Low | Medium | High

High | Medium | High | High

\\ **Medium** \\ Low \\ Medium \\ High \\

\\ **Low** \\ Low \\ Low \\ Medium \\

b). Compare the calculated risk level against \\`Cirque\\`'s **low risk appetite** as defined in \\`IS-CIRQ-P-003-G\\`. Risks assessed as Medium or High will typically require treatment.

c). Record the resulting risk level in the \\`IS-CIRQ-F-001-G: Risk Assessment Register\\`.

****4.8. Documentation**** a. All identified risks, their analysis (likelihood, impact, risk level), and existing controls will be documented in the IS-CIRQ-F-001-G: Risk Assessment Register.

****5. Review and Update****

5. Review and Update

a. Risk assessments will be conducted periodically, and ****high risks will be formally reviewed quarterly**** by the IT Manager and relevant stakeholders. b. The risk assessment process will be reviewed annually as part of the ISMS management review or whenever significant changes in Cirque\\'s context occur.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-003-G: Risk Management Policy
- IS-CIRQ-PR-003-G: Information Security Risk Treatment Procedure
- IS-CIRQ-F-001-G: Risk Assessment Register
- IS-CIRQ-D-001-G: ISMS Scope Document